

PRE-SUBMISSION REVIEW • NSF 26-506 TRACK 3

# RedTwin Submission Review

The proposal is compliant on every mechanical requirement I can check and technically strong. Every compliance item in the Project Description is closed. What remains sits in the budget package: confirm ASU's subaward justification exists, and four smaller fixes in the UCSB justification.

Reviewed against NSF 26-506 • PAPPG 24-1 • last updated 28 Aug 2026

|                              |                              |                         |                     |
|------------------------------|------------------------------|-------------------------|---------------------|
| 15/15                        | 1/1                          | 5/5                     | 4/4                 |
| PROJECT DESCRIPTION<br>PAGES | SUMMARY PAGE • 5<br>KEYWORDS | LETTERS • AT THE<br>CAP | SUPP. DOCS REVIEWED |
| 0                            | 0.45pt                       |                         |                     |
| RULE VIOLATIONS<br>OPEN      | SLACK LEFT ON PAGE<br>16     |                         |                     |

**Status.** The Project Description builds at exactly 15/15 pages and `check.py` passes all eighteen checks with a clean LaTeX log. Sixty-six source edits have been applied across the thirteen section files: the AI-writing rewrites of Section 04 below, the soundness/recall fix, the timeline quarter labels, and five typos. The letter package is at five, the solicitation's maximum. Both required supplementary documents are in `documents/` and both are conformant. Results from Prior NSF Support has been trimmed from five awards to four, which freed roughly nine lines on the last page.

**Update — final pass.** Memory-safe languages (B6) and the Prior Support headings are now in the Project Description. The budget and budget justification have been reviewed for the first time; they are covered below as B10–B14. **The Description is now completely full:** page 16 ends 0.45 pt short of the bottom margin, so any further addition overflows to sixteen pages unless something is cut first. The cheapest cut remains Doupé's CNS-1703375, outside the five-year reporting window.

**Resolved and removed from this page:** B1 (letter count and the exposed third letter), B3 (personnel list, now Times New Roman with complete coverage and corrected names), B4 (the Matni letter claim in Section 11), B5 (the stale `main.pdf`), B7 (Facilities rewritten as `facilities.pdf`; the old draft has been deleted), B6 (memory-safe languages), and T1 (the soundness/recall contradiction). Numbering below is unchanged so earlier references still resolve.

## 00 Before you upload

Three days out, these are the mechanical steps that are easiest to lose.

- **Export the personnel list to PDF.** Research.gov will not take `.docx`. The body runs are Times New Roman 12 pt with 1" margins, so the export is clean; note that the document's *theme* default is still Calibri, so any row added later will need its font set explicitly.
- **Upload `facilities.pdf`** as Facilities, Equipment and Other Resources.
- **Split `main.pdf` into three uploads** — Project Summary, Project Description, References Cited — and enter the Summary into Research.gov's Overview / Intellectual Merit / Broader Impacts text boxes rather than uploading it.
- **Run** `make && make check` **last**, so the uploaded Description is the one that passed; `make docs` rebuilds Facilities and the Mentoring Plan.
- **Confirm the cover-sheet title** reads exactly "PESOSE: Track 3: RedTwin: AI-Enabled Digital Twins for Continuous Red Teaming of Open-Source Ecosystems".
- **Rename** `Grabriele Santomaggio - RabbitMQ.pdf` and fix the same misspelling in the PDF's Title metadata. The ZMap filename is already corrected.
- **Confirm ASU's budget and budget justification** exist in Research.gov (B10).

## 01 What must be fixed before you submit

Ordered by what happens if you don't. Resolved items have been removed — the status note above records what they were. One item (B10) could matter to a grants

officer; the rest are things a reviewer will notice.

#### PARTLY RESOLVED B2

### The nginx and ZMap letters still do not state the importance of the targeted vulnerabilities

Track 3 adds a letter requirement the other tracks do not have: "Letters must [state the] importance of the vulnerabilities to be addressed from the perspective of users." All three letters endorse the *method*, at length and persuasively, but none of them says that the memory-safety, configuration-induced, or request-smuggling classes of Section 4 matter to them or to the people they represent. Buu Lam comes closest ("is my deployment safe") without naming a class; Zakir Durumeric discusses ZMap capability gaps; Foschini discusses synthetic data. This is the requirement most likely to be checked off individually and found unmet.

**Santomaggio's letter now does this, and it is the model to copy.** He names the classes that matter to him as a maintainer: overly permissive virtual-host permissions, a credential shared between a service and the broker, a management interface reachable from a segment nobody intended, and an inter-node channel trusted because it is assumed private. He then says why they persist — "each is unremarkable in isolation" — which is exactly the argument Section 4 makes. The gap now applies only to the two anchor products, which is where a reviewer will look hardest.

#### REMAINING FIX

One added paragraph in each of the nginx and ZMap letters. Buu Lam is well placed to say that configuration-induced traversal and access-bypass defects are what NGINX practitioners actually get wrong, and that IngressNightmare landed hard on the community. Durumeric can say that incomplete or stale inventory is the failure his users hit, and that unpatched hosts follow from it. Each is a sentence they would plausibly write, and each maps to a class you name in Section 4.

#### FIX B8 Visible errors on the face of the letters

Letters/

**Four of the five letters drop "Secure" from the program name**, addressing "Pathways to Enable Open-Source Ecosystems." Only Foschini's is right, and it is on the first four lines of each. The NGINX letter additionally dates itself "August 25st, 2026."

The RabbitMQ letter's contact line still reads `[gabriele.santomaggio@broadcom.com]` | `[3939731936]` : the square brackets read as an unfilled template.

**The ZMap filename is fixed, but the RabbitMQ one picked up a new typo in the rename pass:** Gabriele Santomaggio - RabbitMQ.pdf . The same misspelling is baked into the PDF's Title metadata by the re-save, so both need correcting. That re-save (Word → Quartz) also emits malformed flate streams; the text extracts completely, so it renders, but re-exporting from Word rather than Preview would produce a cleaner file.

SMALL B9

### **Broadcom letterhead sits two acquisitions away from a company Section 11 names**

Section 11 states that Pls Kruegel and Vigna founded Lastline, "a network security company acquired by VMware in 2020." Broadcom acquired VMware in 2023, and the new letter is on Broadcom letterhead. Santomaggio states he has no relationship with the proposing team, and I have no reason to doubt it: a different person in a different business unit, two steps removed, and well outside any NSF conflict window. The letter is fine. But a conflicts reviewer cross-referencing the letterhead against Section 11 could pause over it, so it is worth knowing the adjacency is there before someone else finds it.

#### **IF YOU WANT TO CLOSE IT**

Nothing in the letter needs to change. If you would rather pre-empt the question, a half-sentence in his relationship paragraph noting that he has no connection to Lastline or to its acquisition history would settle it permanently.

### **Budget and budget justification**

The hard limits are met: **\$1,500,000 exactly, over 4/1/27–3/31/29**, against a Track 3 ceiling of \$1.5M for up to two years. The indirect-cost arithmetic checks out — MTDC correctly excludes GSR tuition, GSHIP, equipment, and the subaward beyond the first \$25K, and that \$25K inclusion is applied once over the life of the award rather than per year. Equipment reconciles (\$31,746 + \$2,460 shipping and tax = \$34,206) with the quote attached. Summer salary is well under the two-month disclosure threshold, and there is no cost sharing, which the solicitation prohibits. Five things need attention.

BLOCKER B10

### **Half the money is unexplained: the ASU subaward has no budget justification**

The budget shows **\$742,444** to Arizona State, 49% of the total. The justification never mentions ASU or subawards once, and no ASU budget or justification is in the repo. PAPPG: "For proposals that contain subawards, each subaward includes a separate Budget Justification that does not exceed five pages."

#### VERIFY TONIGHT

These may already exist as a separate budget form inside Research.gov, which is where subaward budgets normally live. If they do, nothing is wrong. If they do not, this is the single largest gap in the package.

#### FIX B11 Travel figures in the justification and the budget disagree

The justification says one project meeting annually "(\$4,717 in total costs)." The budget shows \$2,770 + \$2,772 = **\$5,542**. Neither one meeting nor two produces \$4,717.

Separately, travel funds project meetings only. Section 11 commits to publishing at IEEE S&P, CCS, USENIX Security, and NDSS, and to running an annual public competition, and no line funds either. Reviewers notice when the dissemination plan and the travel budget disagree.

#### FIX B12 Indirect costs are labelled "L"

On the NSF budget form indirect costs are line I; L is "Amount of This Request." The justification runs A, B, C, D, E, G, L. Adding "F. Participant Support Costs: none requested" would also make the skip from E to G explicit.

#### FIX B13 The justification describes half the graduate-student support that is budgeted

It says students are supported "at 50% during the academic year from April through June, and 100% during the summer terms from July through September." The budget also funds six academic months at 50% each October through March, which the justification does not mention.

#### SMALL B14

#### The equipment justification is weak, and your own documents contain the answer

It reads "a server capable of supporting the research necessary to this project." A reviewer

who has just read Facilities — Pod, Knot, a departmental A100 server, the campus cloud — will ask why \$34K of hardware is needed. The real reason is strong: Section 6 requires twins to be held on isolated networks running deliberately exploited software, which cannot be placed on shared campus clusters. One sentence closes it.

ALSO

The budget spreadsheet prints Formula Line: Please Hide and the internal path /Volumes/office/Contracts & Grants/... on both pages. Irrelevant if it is only the research office's working copy and the numbers are keyed into Research.gov's form; fix the hidden row and the footer if it is uploaded.

02 Compliance matrix

Everything I could verify mechanically, checked against the solicitation and PAPPG 24-1. The Project Description itself is in good shape; the gaps are all in the surrounding documents.

| REQUIREMENT                           | STATUS | NOTES                                                                                                                                                      |
|---------------------------------------|--------|------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Title begins "PESOSE: Track 3:"       | PASS   | Correct in the summary heading and PDF metadata. Confirm the Research.gov cover sheet matches exactly.                                                     |
| Project Description ≤ 15 pages        | PASS   | Exactly 15, pp. 2–16. Page 16 is full to the last line, so every addition needs a matching cut.                                                            |
| Project Summary ≤ 1 page, three parts | PASS   | Overview / Intellectual Merit / Broader Impacts all labeled.                                                                                               |
| Keywords: 2–5, semicolons, last line  | PASS   | Five keywords, correctly formatted.                                                                                                                        |
| No URLs in Project Description        | PASS   | Zero. Products cited inline with URLs in References Cited, exactly as the solicitation directs.                                                            |
| Fonts, spacing, margins               | PASS   | 11 pt Times, 5.67 lines/inch (limit 6), margins ≥ 1" within glyph tolerance. Tightest bottom measures 0.96" from descenders; acceptable but with no slack. |
| "Broader Impacts" as its own          | PASS   | Section 11, on its own line                                                                                                                                |

|                                                                       |         |                                                                                                                                                                       |
|-----------------------------------------------------------------------|---------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Broader impacts as its own heading                                    | PASS    | SECTION 11, ON ITS OWN LINE.                                                                                                                                          |
| Pointer to the open-source product                                    | PASS    | nginx and ZMap, with repository entries in References Cited.                                                                                                          |
| Development/testing model, dissemination, user base, contributor base | PASS    | Section 2 covers all four explicitly for both products. This is the best-executed compliance element in the proposal.                                                 |
| Problem statement; team qualification                                 | PASS    | Sections 1 and 10.                                                                                                                                                    |
| Milestones for each year                                              | PASS    | Eight quarters, consistent with the 2-year Track 3 ceiling.                                                                                                           |
| Evaluation plan with metrics and user validation                      | PASS    | Quantified table plus a partner and campus validation phase.                                                                                                          |
| SBOM consideration                                                    | PASS    | Thrust 1, socio-technical risks, and the release process.                                                                                                             |
| CISA/NSA and OpenSSF guidance                                         | PASS    | Cited in Sections 4 and 6, plus SLSA.                                                                                                                                 |
| No cost sharing                                                       | PASS    | Nothing in the Description implies committed cost sharing.                                                                                                            |
| I-Corps first-line note                                               | N/A     | Track 3 is exempt; correctly omitted.                                                                                                                                 |
| Memory-safe languages consideration                                   | PASS    | New labelled paragraph in Thrust 3: why a rewrite is not serviceable, the module boundary as the tractable target, sanitizers and hardened builds for the existing C. |
| ≥ 3 letters from unrelated users/contributors                         | PASS    | Five letters, at the cap. Three unambiguously qualify: nginx, ZMap, RabbitMQ.                                                                                         |
| Letters address vulnerability importance to users                     | PARTIAL | See B2. The RabbitMQ letter does it well; the two anchor-product letters still do not.                                                                                |
| Letters ≤ 2 pages, with name, affiliation, relationship               | PASS    | All five are exactly 2 pages and all five disclose relationship explicitly. Well done, and unusual.                                                                   |
| Personnel/collaborators list                                          | PASS    | All four PIs and all five letter writers, Times New Roman 12 pt, 1" margins. Export to PDF before upload.                                                             |
| Facilities, Equipment and                                             | PASS    | facilities.pdf , 3 pp.: no financial information,                                                                                                                     |



|                                            |        |                                                                                                                                                                                                                                                                                             |
|--------------------------------------------|--------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Other Resources                            |        | collaborators described per PAPPG II.D.2.d(iv), all placeholders resolved.                                                                                                                                                                                                                  |
| Prior support: two distinct headings       | PASS   | Now bold <i>Intellectual Merit</i> and <i>Broader Impacts</i> , matching PAPPG's wording and visually distinct from the italic Publications / Products / Relation labels.                                                                                                                   |
| Budget ≤ \$1,500,000                       | PASS   | \$1,500,000 exactly. Indirect-cost and MTDC arithmetic verified.                                                                                                                                                                                                                            |
| Duration ≤ 2 years                         | PASS   | 4/1/27–3/31/29, matching the eight-quarter timeline.                                                                                                                                                                                                                                        |
| Separate budget justification per subaward | VERIFY | See B10. Not in the repo; may exist inside Research.gov.                                                                                                                                                                                                                                    |
| Prior support: one award per PI permitted  | PASS   | Four awards, down from five: CNS-2247954 was dropped, leaving PI Bao with one. Two optional trims remain if you want more space — Vigna and Kruegel still list both ACTION and Bedrock, and Doupé's CNS-1703375 ended in 2021, outside the five-year window that makes reporting mandatory. |
| Data Management and Sharing Plan           | CHECK  | Not in repo. Separate required upload; presumably being handled outside this repo, but worth confirming, particularly given the synthetic-medical-data component.                                                                                                                           |

### 03 Technical content and structure

The proposal is well argued and the technical core is genuinely novel. The issues below are the ones a knowledgeable panelist will raise, ordered by how much they would cost you.

HIGH

T2

**The framing invites the reading "a digital-twin research project with two products bolted on"**

This is the strategic risk in the proposal. The three research thrusts are about the framework; nginx and ZMap enter as targets and beneficiaries. Track 3, though, funds improving the safety



and security of an existing ecosystem, and the panel will include people who read the tracks strictly. The concrete ecosystem deliverable is " $\geq 10$  confirmed defects reported upstream" across nginx, ZMap, and dependencies, which for a \$1.5M award aimed at ecosystem hardening is modest, and defect counts are partly outside your control anyway.

#### SUGGESTED FIX

Add durable, non-count deliverables that survive whether or not particular bugs are found: a configuration-defect checker landed in nginx or ingress-nginx CI rather than released as a standalone tool; fuzz harnesses contributed to OSS-Fuzz for the request path and the historically defect-prone optional modules; a named OpenSSF Best Practices badge level as a target for your own release process; and a published corpus of real deployed nginx configurations, which would be a genuinely new community artifact and follows directly from Thrust 1. Then say in one sentence that hardening nginx and ZMap is the goal and RedTwin is the instrument, rather than the reverse.

#### HIGH T3 **Scale claims and scale evidence do not meet**

The motivation is "large computing infrastructures" and a regional hospital; Insight 1 is illustrated with 200 file servers; the resource target is " $\geq 10\times$  reduction at equal soundness." The plan delivers reference networks of 10–20 hosts, a 20-host twin at " $\geq 5\times$  reduction" by Q4, and a planner that "scales to 100 hosts" by Q8. A  $10\times$  reduction is not meaningfully demonstrable on 20 hosts, and 100 hosts is one or two orders of magnitude below the motivating deployment.

#### SUGGESTED FIX

State the largest infrastructure you will attempt and attach the  $10\times$  claim to that scale explicitly, then say what carries the argument beyond it. The equivalence-class lifting in Thrust 3 is exactly the right answer, so make the scaling argument analytic rather than empirical: cost grows with the number of equivalence classes, not hosts, and classes saturate. One paragraph converts an apparent gap into a contribution.

#### MEDIUM T4

#### **On production, every claim reduces to an estimated coverage number that is only validated on 20-host networks**

The proposal is admirably candid that soundness is "soundness relative to the captured model" and that coverage is reported alongside every finding. But the fidelity measure compares two attack graphs both derived from the same captured model, so on production it

validates replication only and is blind to capture error. Capture error is bounded by the coverage *estimate*, and the estimate's own accuracy is checked only against reference-network ground truth. The obvious panel question is why an estimator calibrated on a 20-host synthetic network should be trusted on a hospital.

#### SUGGESTED FIX

Add one concrete production-side validation to the evaluation plan: a withhold-and-reveal protocol in which the partner's administrators disclose a ground-truth subset only after capture converges, or a planted-asset exercise in which they introduce a host, service, or trust relation the system is not told about. Either gives you a real measurement of coverage-estimator accuracy outside the reference networks, and it is cheap.

MEDIUM T5

### Upstream acceptance is treated as given, and nginx governance is the one live example Track 3 is asking about

Section 6 says improvements are "developed as upstream contributions from the start ... rather than being maintained as a fork." nginx is conservative about outside patches and the project experienced a maintainer fork in 2024, and your `references.bib` contains an unused `freenginx` entry, which suggests you drafted this discussion and cut it for space. Meanwhile Section 4 raises maintainer and governance concentration as a socio-technical risk and illustrates it with xz-utils, a different project. Your own anchor product supplies a better and more current example, and you left it out. Also worth noting: Zakir Durumerić's letter is from an actual ZMap maintainer and explicitly welcomes upstreaming; Buu Lam's is community-facing and hedged with "subject to the usual internal review at F5." Your ZMap upstream path is solid, your nginx path is not.

#### SUGGESTED FIX

Restore two sentences on nginx governance, and name a fallback for each anchor: for nginx, contribute to ingress-nginx or to distribution packaging, both of which have different governance and, in ingress-nginx's case, are where your flagship incident actually lives. This is one of the few places where an honest risk discussion strengthens rather than weakens the proposal, because it is the exact socio-technical territory Track 3 names.

MEDIUM T6

### No human baseline for the claim that experts shift from assessment to verification

The multi-step baselines are your own ChainReactor and MulVAL. The central value claim

The multi-step baselines are your own ChainReactor and MultiVAL. The central value claim, though, is that RedTwin shifts scarce experts from manual assessment to verifying high-confidence findings, and the thing being displaced is a human red team. The evaluation says it "will report the human effort required at each stage" but never measures the alternative.

#### SUGGESTED FIX

A small human baseline: two or three red teamers, two reference networks, fixed time budget, measuring chains found and hours spent, against RedTwin on the same networks. With ground truth already available, this is a few days of work and it converts your headline claim from rhetoric into a number.

#### MEDIUM T7 **The Sage Bionetworks data dependency has no timeline slot and no fallback**

Insight 3 leans on Sage-brokered medical data for realistic synthetic datasets, and Foschini's letter makes everything conditional on governance review that "exists independently of this award." The timeline table never mentions medical data or a governance milestone. A reviewer sees an unmitigated external dependency on the critical path of a two-year project.

#### SUGGESTED FIX

Put the governance-approval milestone in Q3–Q4 with an explicit fallback to fully synthetic FHIR and DICOM generation, and say that the authorization-structure work of Thrust 2 does not depend on real data at all, which is true and which defuses the concern entirely.

#### MEDIUM T8 **Personnel loading appears nowhere, and Q1–Q2 and Q7–Q8 are overloaded**

Q1–Q2 promises the knowledge-base schema, documentation agents, two reference networks, Observer Agents, passive observation, service-dependency capture, and the first ZMap safety extensions, all in six months. Q7–Q8 promises networked multi-step planning, the analyst workflow, continuous cadences and cost reduction, partner and campus evaluation, and the public release of framework, benchmark, and twinCTF challenges. Nothing in the Project Description says how many students or postdocs sit on each thrust, so a reviewer has no way to judge whether the schedule is credible and will assume it is not.

#### SUGGESTED FIX

Two sentences in the management paragraph giving the staffing per thrust per site. Section 10 is currently the thinnest section relative to its job.

#### SMALL T9 **Assorted internal inconsistencies and under-defined targets**

- **"Each year ends with a go/no-go review"** but only the Q4 gate has criteria, and a gate at Q8 is the end of the award. Say "the first year ends with a go/no-go review."
- **"No measurable latency or error change"** is not falsifiable as written; with enough samples something is always measurable. Give a threshold, for example no change beyond the p99 latency noise band at stated power.
- **"Cost per assessment cycle: reported; reduced  $\geq 2\times$ "** needs a baseline. Reduced relative to the first working end-to-end version, presumably; say so.
- **"Model coverage estimate vs. measured within 10 points"** is only meaningful where ground truth exists. The table says targets are for reference networks, so this is fine, but it is the metric T4 turns on and deserves a production analogue.
- **The continuous cadence has no cost envelope.** Nightly component analysis and weekly full planning over a 100-host twin, with fuzzing and LLM inference, is expensive. You name cost as a first-class metric but give no order of magnitude and no compute source. One sentence with a rough envelope and where the compute comes from will read as command of the engineering rather than as an omission.
- **IngressNightmare is your flagship incident but ingress-nginx is not an anchor product.** Either name it in Section 2 or say explicitly that it is illustrative. Reviewers dislike a motivating incident the plan does not reach.
- **twinCTF has no target.** It is a headline broader impact and a claimed measure of success, with no participation number and no first-run year. Add both.
- **Figure labels render at 5.9 pt.** Legal, since PAPPG permits sub-10 pt in figures, but hard to read in print, and the twin panel appears to show the same number of hosts as the target panel, which contradicts Insight 1. Redrawing with fewer icons, larger labels, thrust annotations, a visible multiplicity reduction on the twin side, and the fidelity-comparison arrow that is currently missing would make the figure carry its own weight.
- **Related work omits cloud attack-path analysis**, the closest commercial analogue to the knowledge-graph-plus-attack-path design, and network deception and honeynet work, which also builds replicas. Both are one clause each.

## 04 Passages that read as AI-generated

**APPLIED** Every rewrite in this section has been made in the sources, along with the same treatment applied consistently to comparable passages elsewhere. Measured after the pass: "rather than" 17 → 5, "..., as" causal clauses 24 → 13, "precisely/exactly" 10 → 3 (all three remaining are literal, not intensifiers), "is not a X..." 3 → 1, negative parallelisms 4 → 2. The counts include the restored future-proofing paragraph, which contributes none of them. Sentence-length distribution is deliberately unchanged (mean 29.1 → 28.6, standard deviation 18.3 in both), since the rhythm was already good and the risk in this kind of pass is flattening it.

The prose is strong: sentence rhythm is genuinely varied (mean 29 words, standard deviation 18, range 4 to 162), and the usual AI vocabulary is almost entirely absent, with one "crucial" and no "underscores," "showcases," "landscape" outside the required section name, or "leverages" beyond legitimate technical use. What flags the document is not word choice but the repetition of three rhetorical moves at a density no human writer sustains.

**Tell 1 — Antithesis saturation**

Seventeen "rather than," three "is not a X, it is a Y," plus "not merely," "not just," and several "instead of." Almost every substantive claim in the proposal is framed as a contrast with what it is not, rather than stated directly. Individually each is a good sentence; cumulatively the reader starts hearing the template instead of the content. Aim to cut the count by half, keeping the ones where the contrast is genuinely the point.

|                                                                                                                                                                                                     |                                                                                                                                                         |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
| NOW                                                                                                                                                                                                 | “The security of nginx and ZMap is not a property of two programs. It is a property of everything built on top of them.”                                |
| TRY                                                                                                                                                                                                 | “Because nginx and ZMap sit beneath so much other software, their defects are inherited by every deployment rather than contained within the products.” |
| Section 3 opening. States the mechanism instead of performing the reveal. It also loses the two-sentence drumbeat that opens the section on a rhetorical flourish where a reviewer wants the claim. |                                                                                                                                                         |

|     |                                                                                                                    |
|-----|--------------------------------------------------------------------------------------------------------------------|
| NOW | “Applied naively, the very property that makes ZMap valuable, its speed, is what makes it unsafe here.”            |
| TRY | “The probe rate that makes ZMap useful for internet-wide measurement is unsafe inside a network of family devices” |

inside a network of fragile devices.

Section 2. Same content, no chiasmus. "The very property that ..." is one of the most recognizable AI constructions in the document.

NOW

“In every case, the advisory establishes that a defect exists, and only the deployment determines whether it matters.”

TRY

“In each of these cases the advisory establishes that a defect exists, while exploitability depends on deployment-specific configuration that no advisory records.”

Section 4. Keeps the argument, drops the epigram. "Only X determines whether it matters" is the shape to watch for.

NOW

“The twin is therefore not a convenience for developers, but a security artifact with quantifiable representativeness.”

TRY

*Delete the sentence.*

Section 1. The preceding three sentences already establish that the twin is measured against explicit security properties and kept synchronized. This sentence restates the conclusion in more emphatic words and adds nothing, which is the paraphrastic-repetition pattern.

**Tell 2 — Aphoristic paragraph-closers**

Around twenty paragraphs end on a quotable, self-contained line. A few examples: "because hosts that are unknown are also hosts that are unpatched"; "an unmaintained module is thus an unpatched vulnerability that has no advisory to trigger an update"; "They are the paradigmatic case for a fidelity-controlled twin"; "a class of defect that can only be found by testing the pair"; "Reference networks establish correctness, but only real deployments establish usefulness"; "because defenders cannot use what they cannot obtain"; "and the graph is only as good as the inventory it is given"; "which turns the durability of the approach into a measurement rather than a promise." Human proposal writing has two or three of these in fifteen pages, deployed where the emphasis is earned. At twenty, the emphasis flattens and the cadence becomes audible. Keep the four or five best, and convert the rest to plain closing statements or cut them.



|                                                                                                                                                     |                                                                                                                            |
|-----------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| NOW                                                                                                                                                 | “They are the paradigmatic case for a fidelity-controlled twin.”                                                           |
| TRY                                                                                                                                                 | “Detecting them therefore requires a replica that reproduces the deployed configuration, which is what Thrust 2 provides.” |
| Section 4. Replaces a verdict with a mechanism and a forward pointer. "Paradigmatic" is doing no work that "therefore requires" does not do better. |                                                                                                                            |

|                                                                  |                                                                                                                                                          |
|------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| NOW                                                              | “... it disproportionately helps those that cannot afford commercial alternatives ... because hosts that are unknown are also hosts that are unpatched.” |
| TRY                                                              | “... because hosts absent from the inventory are not patched when an advisory lands.”                                                                    |
| Section 3. Same point, stated once, without the mirrored clause. |                                                                                                                                                          |

**Tell 3 — Meta-commentary asserting your own rigor**

Roughly eight passages tell the reader that the proposal is being careful, rather than simply being careful: "A distinguishing feature of the approach is that the fidelity of the twin is quantified rather than assumed" (which appears in both the summary and, in a variant, the evaluation plan); "a central methodological commitment of this project is to measure that incompleteness rather than assume it away"; "and it is a trade-off that RedTwin makes explicit and quantifiable"; "Mocks are a principled source of false negatives"; "we treat the resulting dual-use considerations explicitly"; "Because continuity is the central claim of this project, we quantify it rather than assert it"; "We are explicit about the limits of this guarantee, because overstating it would be the most consequential error this project could make." One such passage reads as intellectual honesty and is worth having. Eight reads as performance, and reviewers who notice the pattern begin discounting the claims it decorates.

|                                                                                                                                                                                             |                                                                                                                                             |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| NOW                                                                                                                                                                                         | “We are explicit about the limits of this guarantee, because overstating it would be the most consequential error this project could make.” |
| TRY                                                                                                                                                                                         | “This guarantee has a specific limit.”                                                                                                      |
| Section 5, "What soundness can and cannot mean here." The paragraph that follows is excellent and does not need a preamble announcing its own virtue. The dramatic superlative is the tell. |                                                                                                                                             |



|                                                                                                                                                                                             |                                                                                                                                                                                                          |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| NOW                                                                                                                                                                                         | “Mocks are a principled source of false negatives, as a mock reproduces behavior that was observed, whereas exploitable behavior is very often behavior that was never observed.”                        |
| TRY                                                                                                                                                                                         | “Mocks introduce false negatives by construction: a mock reproduces only behavior the Observer Agents recorded, and exploitable behavior is frequently behavior that was never exercised in production.” |
| Section 5. "Principled" is self-praise; "by construction" is the actual technical claim and is stronger. The rewrite keeps one clean contrast instead of an observed/never-observed mirror. |                                                                                                                                                                                                          |

The future-proofing passage, rewritten rather than cut

The 278-word subsection "Robustness to the evolution of language models" at the end of Section 7 was the weakest *writing* in the proposal, but the argument inside it is one the PIs want to make and a panel will want to hear. My first pass cut it to 78 words, which lost too much; it has since been restored at roughly its original length in the document's revised voice. Four things were wrong with the original, and all four are fixed:

- **It opened defensively.** "RedTwin is not a crutch for the current limitations of large language models" argues against a charge no reviewer had made, and "A distinguishing feature of the design" repeated a phrase from the Project Summary. It now opens on the architectural fact.
- **The central claim was not falsifiable.** Structure-versus-judgment was asserted as a virtue. The model-substitution experiment now cuts both ways, which is the substantive improvement.
- **It closed on an aphorism** — "the value of RedTwin lies precisely in allowing defenders to keep pace" — the same shape as twenty other paragraphs.
- **It was an argument where the section wants a plan.** The substitution now has a cadence: once at each annual review, against the fixed ground-truth benchmark.

|     |                                                                                                                                                                                                                                                                                                                                                                                                                            |
|-----|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| WAS | “A distinguishing feature of the design is that RedTwin is not a crutch for the current limitations of large language models. It is a set of processes that encode <i>structure</i> and delegate <i>judgment</i> , and this division is what makes the framework durable. ... This matters because the same advances accrue to the adversary, and the value of RedTwin lies precisely in allowing defenders to keep pace.” |
|-----|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

value of RedTwin lies precisely in allowing defenders to keep pace.

#### NOW

“The design of RedTwin separates the components that are independent of any model from the judgments that are delegated to one. ... We will run that substitution across models of differing capability at each annual review, and it tests the separation as much as it tests the models: if some substitution requires a change to the schema, to the observation planner, or to the planning formulation, then the boundary between structure and judgment has been drawn in the wrong place, and we will report where it belongs. The same gains in capability accrue to the adversary, and the substitution experiment measures how much of each gain the defender collects.”

Full argument preserved at ~250 words. Zero instances of "rather than," "not only," "precisely," ", as" causals, or the "not X, it is Y" shape; sentence lengths run 17 to 65 words. The revision is a stronger position than the original, because it survives the reviewer who asks how you would know if you were wrong.

### Tell 4 — The enumerated-announcer template

Seven instances of the same sentence shape: "Three challenges shape the design." / "Two further risks are in scope." / "Two assumptions bound the work." / "Organizations usually have to deal with three types of data." / "We plan to approach this problem in two ways." / "We will pursue this along three lines." / "Two dependencies govern this schedule." Two or three of these are good signposting in a dense proposal. Seven is a template. Fold three or four of them into the sentence that follows, for example replacing "Two assumptions bound the work. First, RedTwin evaluates the security of the deployment, and physical attacks, social engineering, and the compromise of the virtualization platform are out of scope" with "RedTwin evaluates the security of the deployment, so physical attacks, social engineering, and compromise of the virtualization platform are out of scope."

**What not to change.** Do not strip the logical connectives while doing this. The proposal's argument is tightly chained and that chaining is a strength; the fix is to vary the rhetorical *move*, not to delete transitions and leave disconnected sentences behind. Choppy prose reads as automated cleanup and is worse than the original. Also leave the sentence-length variation alone: it is already in the range good human technical writing occupies.

## 05 Copy-edit pass